My ZIP isn't your ZIP: Identifying and Exploiting Semantic Gaps Between ZIP Parsers

Content

My ZIP isn't your ZIP: Identifying and Exploiting Semantic Gaps Between ZIP Parsers

Yufan You, *Tsinghua University;* Jianjun Chen, *Tsinghua University; Zhongguancun Laboratory;* Qi Wang, *Tsinghua University;* Haixin Duan, *Tsinghua University; Zhongguancun Laboratory*

Distinguished Paper Award Winner

ZIP is one of the most popular archive formats. It is used not only as archive files, but also as the container for other file formats, including office documents, Android applications, Java archives, and many more. Despite its ubiquity, the ZIP file format specification is imprecisely specified, posing the risk of semantic gaps between implementations that can be exploited by attackers. While prior research has reported individual such vulnerabilities, there is a lack of systematic studies for ZIP parsing ambiguities.

In this paper, we developed a differential fuzzer ZipDiff and systematically identified parsing inconsistencies between 50 ZIP parsers across 19 programming languages. The evaluation results show that almost all pairs of parsers are vulnerable to certain parsing ambiguities. We summarize our findings as 14 distinct parsing ambiguity types in three categories with detailed analysis, systematizing current knowledge and uncovering 10 types of new parsing ambiguities. We demonstrate five real-world scenarios where these parsing ambiguities can be exploited, including bypassing secure email gateways, spoofing office document content, impersonating VS Code extensions, and tampering with signed nested JAR files while still passing Spring Boot's signature verification. We further propose seven mitigation strategies to address these ambiguities. We

responsibly reported the vulnerabilities to the affected vendors and received positive feedback, including bounty rewards from Gmail, Coremail, and Zoho, and three CVEs from Go, LibreOffice, and Spring Boot.

Category:

Long Presentation

Open Access Media

USENIX is committed to Open Access to the research presented at our events. Papers and proceedings are freely available to everyone once the event begins. Any video, audio, and/or slides that are posted after the event are also free and open to everyone. Support USENIX and our commitment to Open Access.

BibTeX

@inproceedings {309802, author = {Yufan You and Jianjun Chen and Qi Wang and Haixin Duan}, title = {My {ZIP} isn{\textquoteright}t your {ZIP}: Identifying and Exploiting Semantic Gaps Between {ZIP} Parsers}, booktitle = {34th USENIX Security Symposium (USENIX Security 25)}, year = {2025}, isbn = {978-1-939133-52-6}, address = {Seattle, WA}, pages = {431--450}, url = {https://www.usenix.org/conference/usenixsecurity25/presentation/you}, publisher = {USENIX Association}, month = aug }

Download

[image: PDF icon] You PDF

[image: PDF icon] You Appendix PDF

[image: image]

View the slides

[image: image]

[image: image]

[image: image]

Presentation Video